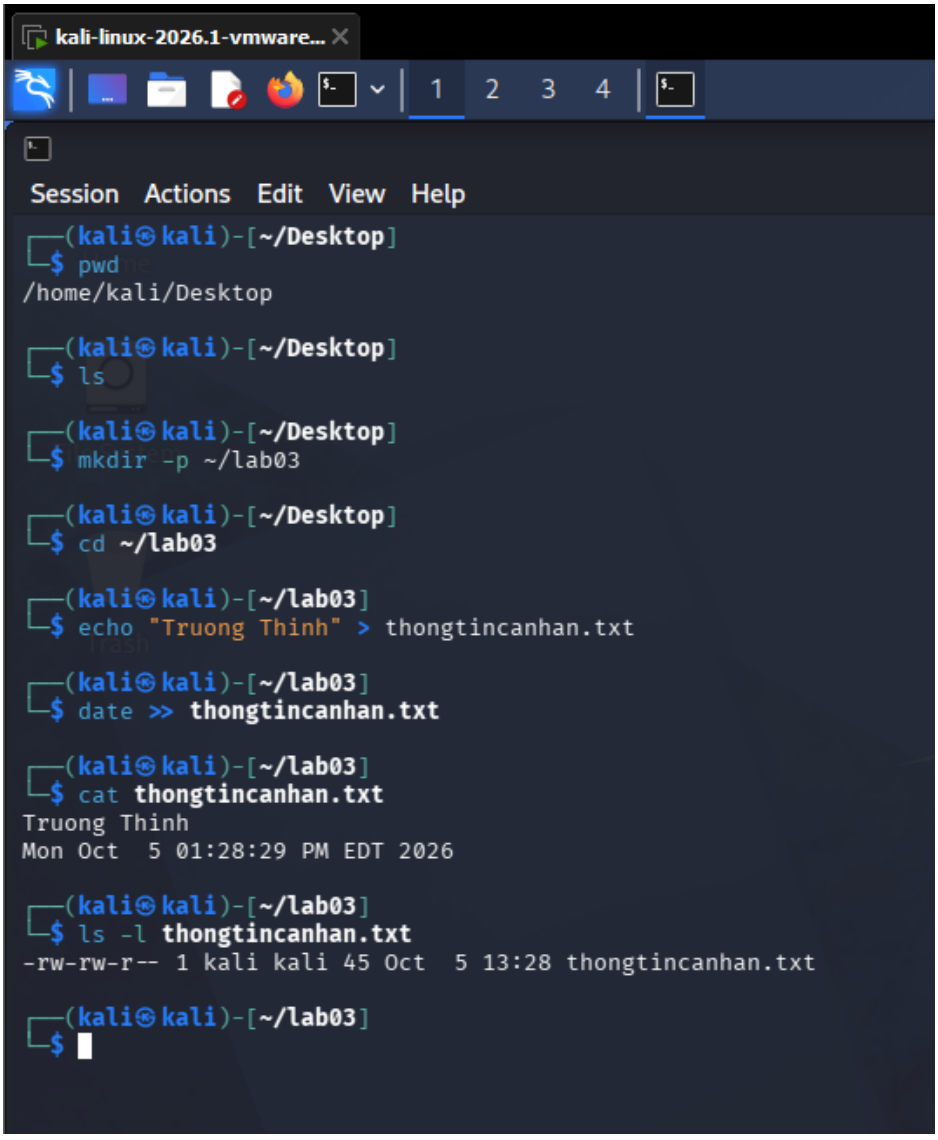
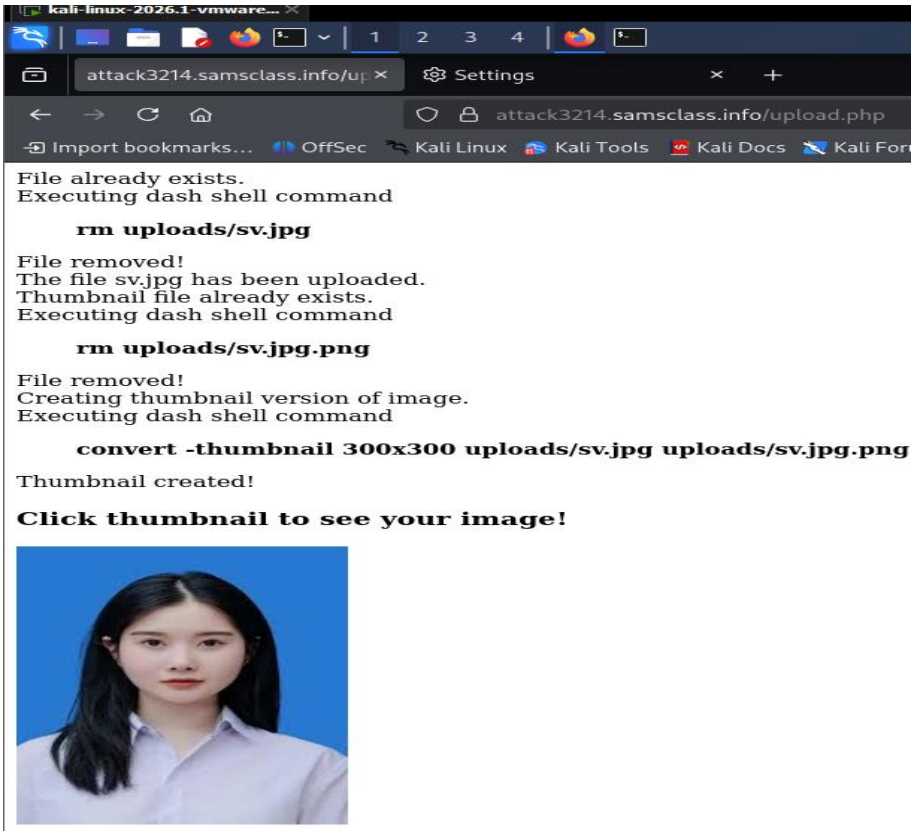
Trần Tăng Trường Thịnh 2387701939

BÀI 3: COMMAND, INJECTION VÀ SQL INJECTION

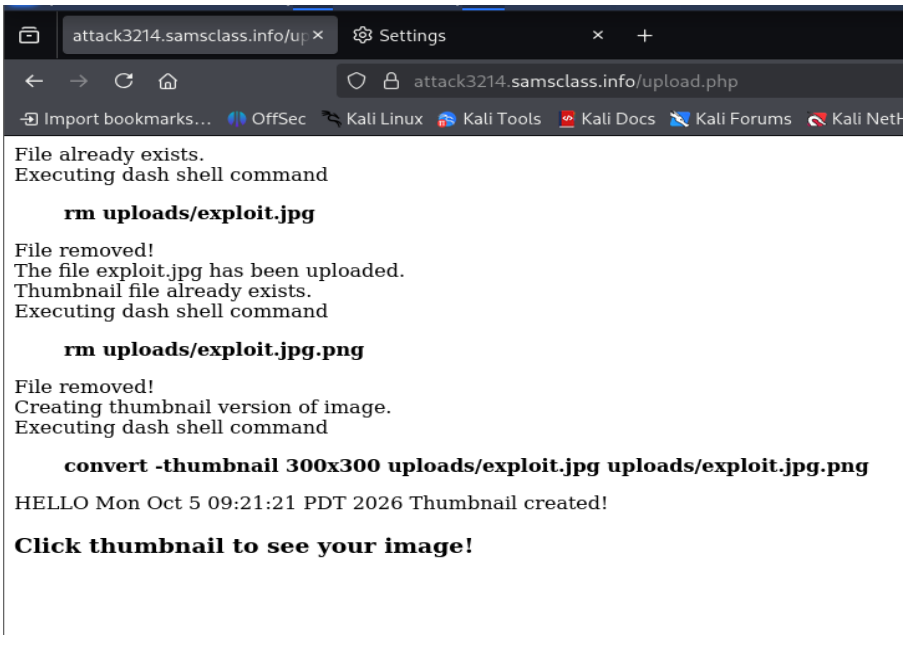
3.1 COMMAND INJECTION



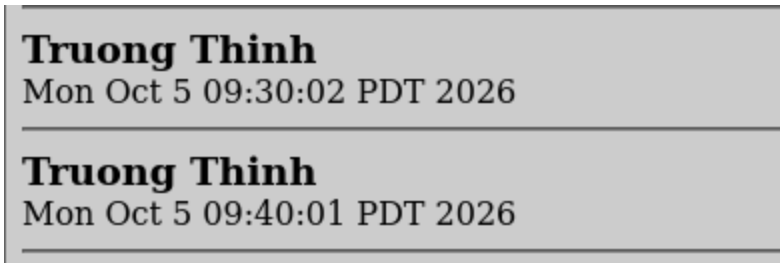
Hình 1: 1 vài lệnh cơ bản



Hình 2: Test upload hình ảnh



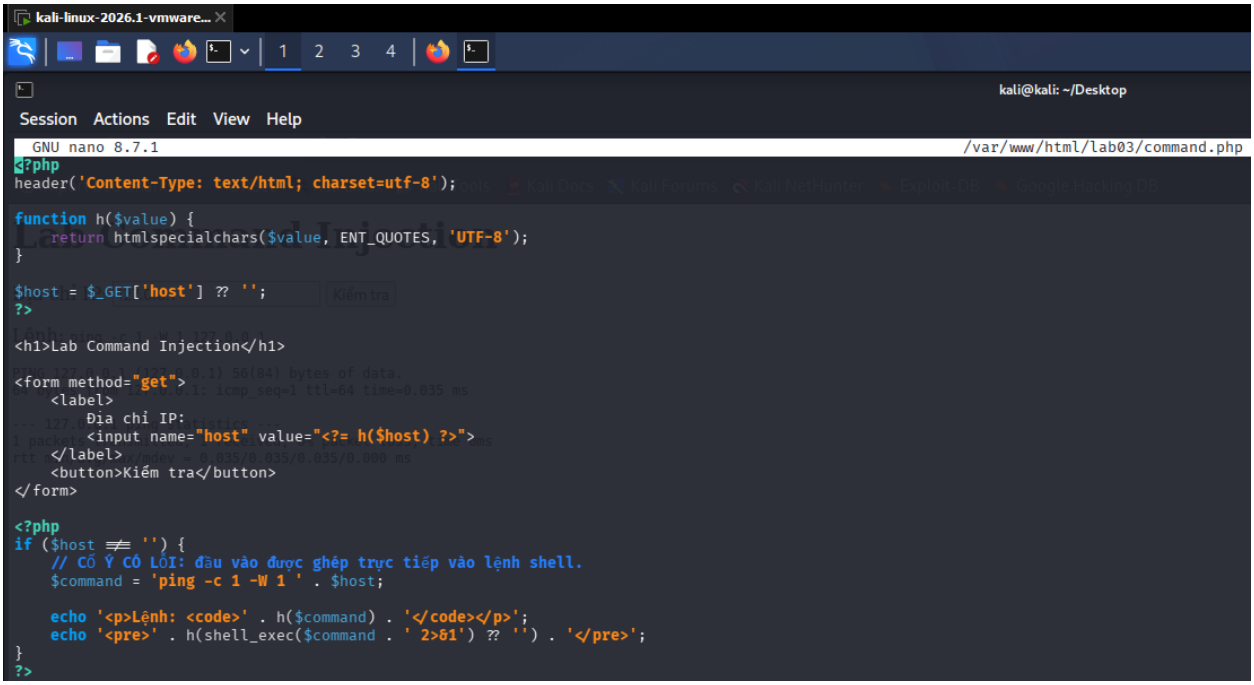
Hình 3: Kết quả khai thác ImageMagick



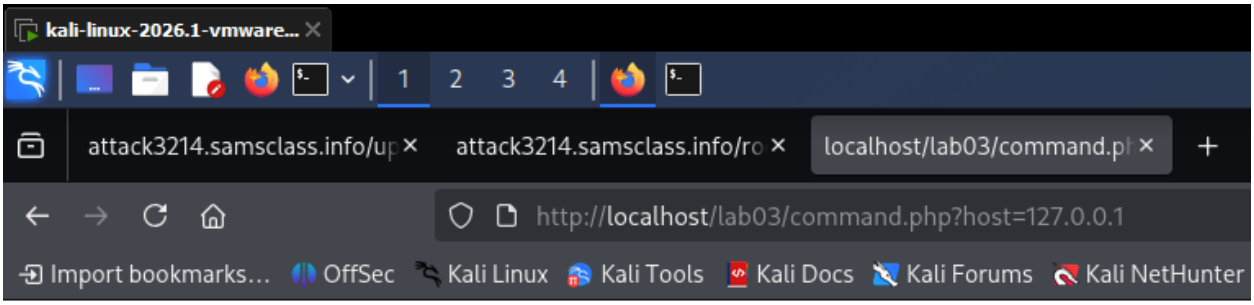
Hình 4: Kết quả khai thác thành công: tên “Truong Thinh” xuất hiện trên bảng Winner.



Hình 5: Đoạn code trong file



Hình 6: Đoạn code trong file command.php



Lab Command Injection

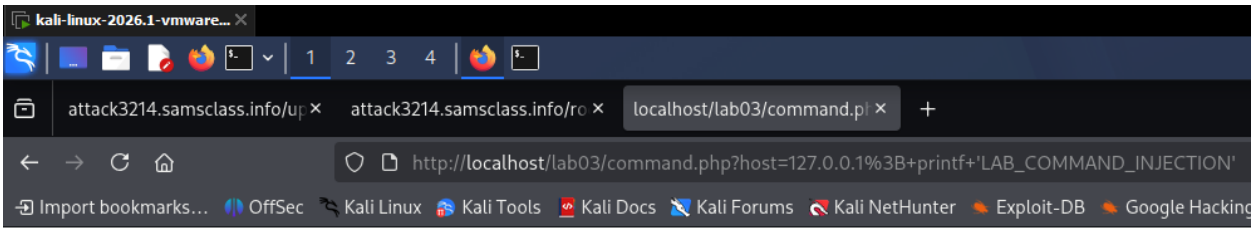
Địa chỉ IP: 127.0.0.1 Kiểm tra

Lệnh: `ping -c 1 -W 1 127.0.0.1`

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.035 ms

--- 127.0.0.1 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.035/0.035/0.035/0.000 ms
```

Hình 7: Kiểm tra chức năng ping với địa chỉ IP hợp lệ *127.0.0.1*.



Lab Command Injection

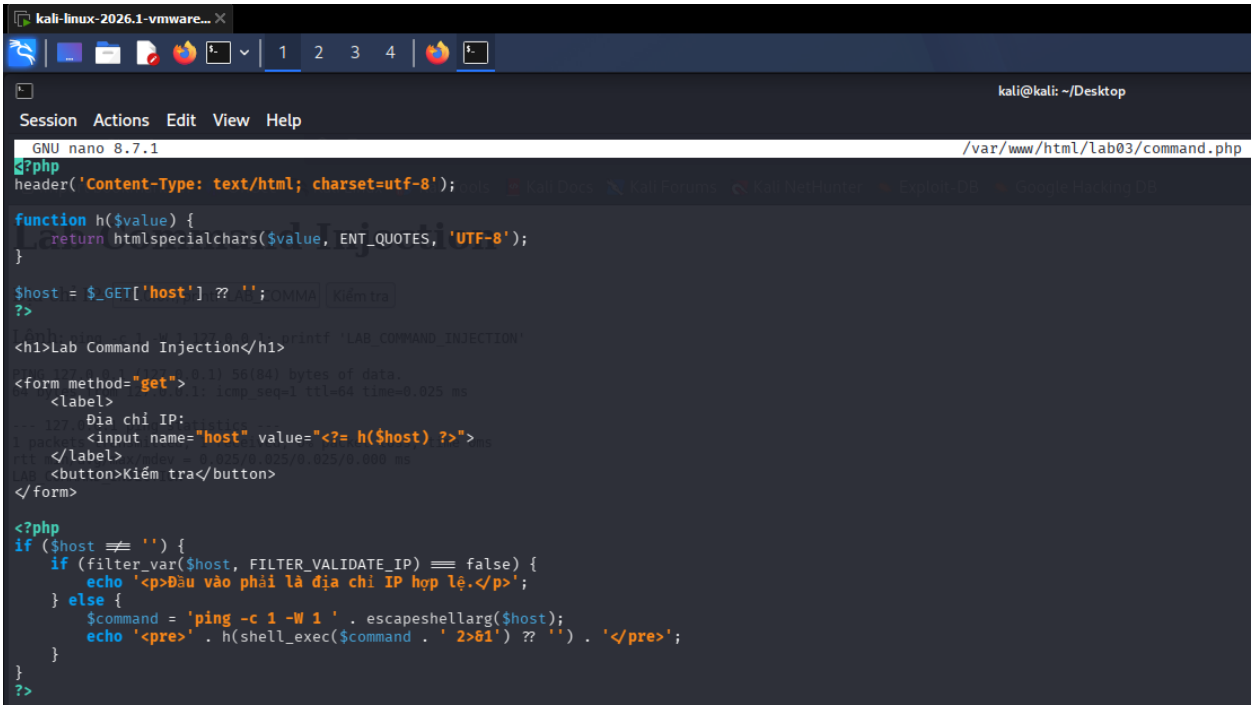
Địa chỉ IP: 127.0.0.1; printf 'LAB_COMMA Kiểm tra

Lệnh: `ping -c 1 -W 1 127.0.0.1; printf 'LAB_COMMAND_INJECTION'`

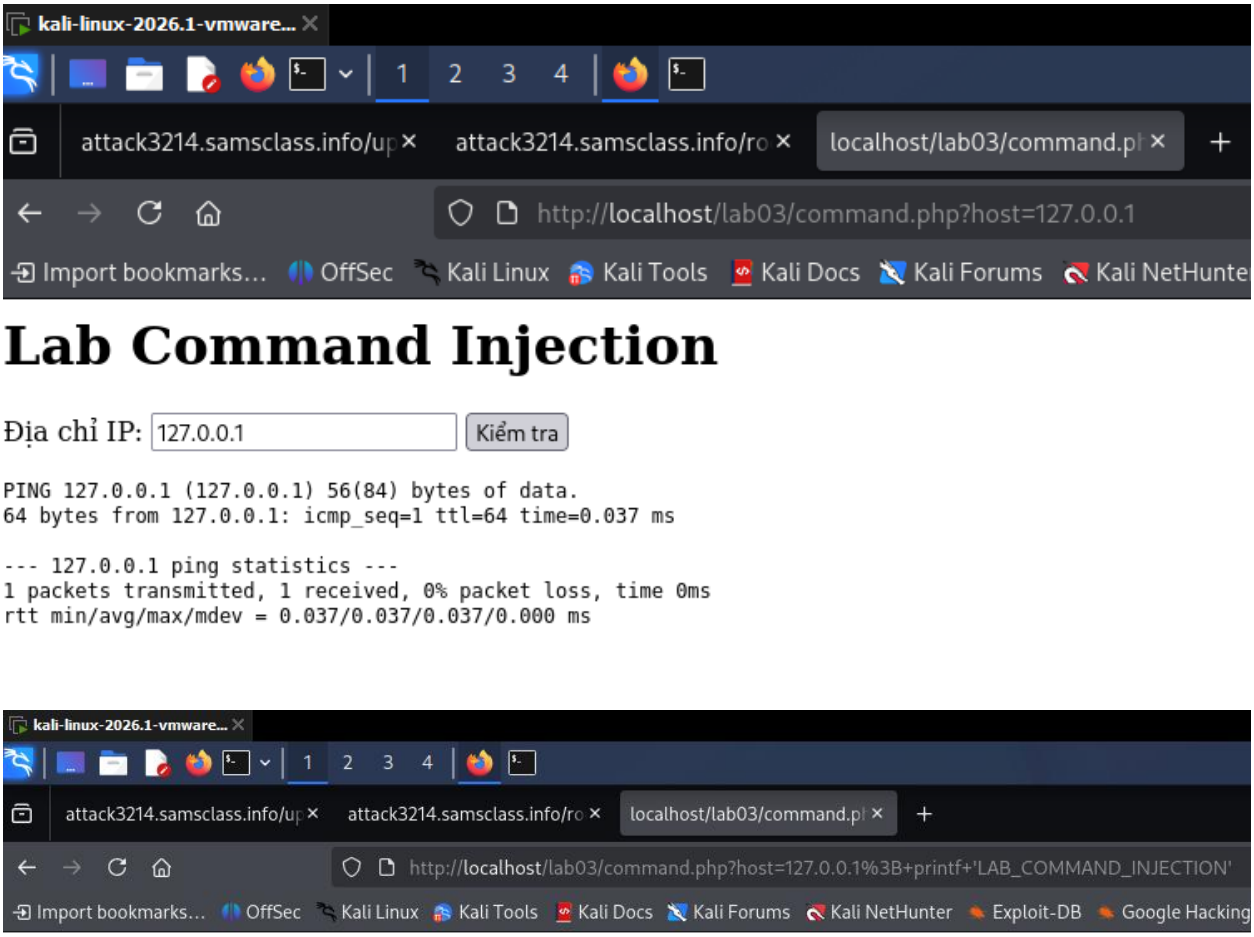
```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.025 ms

--- 127.0.0.1 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.025/0.025/0.025/0.000 ms
LAB_COMMAND_INJECTION
```

Hình 8: Khai thác thành công lỗ hổng Command Injection thông qua tham số *host*.



Hình 9: Đoạn code trong file *command.php* sau khi vá



Hình 10: Sau khi vá, payload không hợp lệ bị từ chối

3.2 SQL INJECTION SỬ DỤNG CƠ SỞ DỮ LIỆU SQLOL

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo docker version
sudo docker compose version
Client:
 Version:           28.5.2+dfsg4
 API version:       1.51
 Go version:        go1.26.5
 Git commit:        9cc6dea35e9a963f281434761c656fba4ac43aed
 Built:             Tue Aug 11 15:35:37 2026
 OS/Arch:           linux/amd64
 Context:           default

Server:
 Engine:
  Version:          28.5.2+dfsg4
  API version:      1.51 (minimum version 1.24)
  Go version:       go1.26.5
  Git commit:       3ef3c07c883be49a2e8097bcf6d2952fce1d70eb
  Built:            Tue Aug 11 15:35:37 2026
  OS/Arch:          linux/amd64
  Experimental:     false
 containerd:
  Version:          2.1.9+unknown
  GitCommit:
 runc:
  Version:          1.3.6+ds1
  GitCommit:        1.3.6+ds1-1
 docker-init:
  Version:          0.19.0
  GitCommit:
Docker Compose version 2.40.3-3
```

Hình 11: Kiểm tra docker version

```
┌──(kali㉿kali)-[~/Desktop]
└─$ mkdir -p ~/sqlol-lab
cd ~/sqlol-lab

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ ls

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ nano compose.yaml

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ nano Dockerfile

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ sudo ss -ltnp | grep ':80 '
LISTEN 0      511                *:80              *:*    users:(("apache2",pid=36232,fd=4),("apache2",pid=36231,fd=4),("apache2",pid=36230,fd=4),("apache2",pid=36229,fd=4),("apache2",pid=36228,fd=4),("apache2",pid=899,fd=4))

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ ss
```

Hình 12: Kiểm tra cổng 80

```
┌──(kali㉿kali)-[~/sqlol-lab]
└─$ cd ~/sqlol-lab

curl -fL https://samsclass.info/124/proj11/sqlol-sbowne.tgz -o sqlol-sbowne.tgz
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100 541.7k 100 541.7k    0     0 583.7k      0                              0

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ tar -xzf sqlol-sbowne.tgz

┌──(kali㉿kali)-[~/sqlol-lab]
└─$ ls sqlol
challenges      CHANGELOG   delete.php  index.php   license.txt  resetbutton.php   search-fix.php  search.php  simple2.tar  store1.php  update.php
challenges.htm  custom.php  includes    insert.php  README.txt   search-fixed.php  search.htm      select.php  simple.php   temp.php

┌──(kali㉿kali)-[~/sqlol-lab]
└─$
```

Hình 13: Tải và cài đặt SQLol

```
Session  Actions  Edit  View  Help
  GNU nano 8.7.1
/*
SQLol - A configurable SQL injection testbed
Daniel "unicornFurnace" Crowley
Copyright (C) 2012 Trustwave Holdings, Inc.

This program is free software: you can redistribute it and/or modify it und

This program is distributed in the hope that it will be useful, but WITHOUT

You should have received a copy of the GNU General Public License along wit
*/

//Choose the appropriate type of database here

//Choose me for MySQL
$dbtype = 'mysql';
$server = 'db';
$port = '3306';
$username = 'root';
$password = 'password';
$database = 'sqlol';
$persist = '';

$hostspec = $username.':'.$password.'@'.$server.':'.$port;

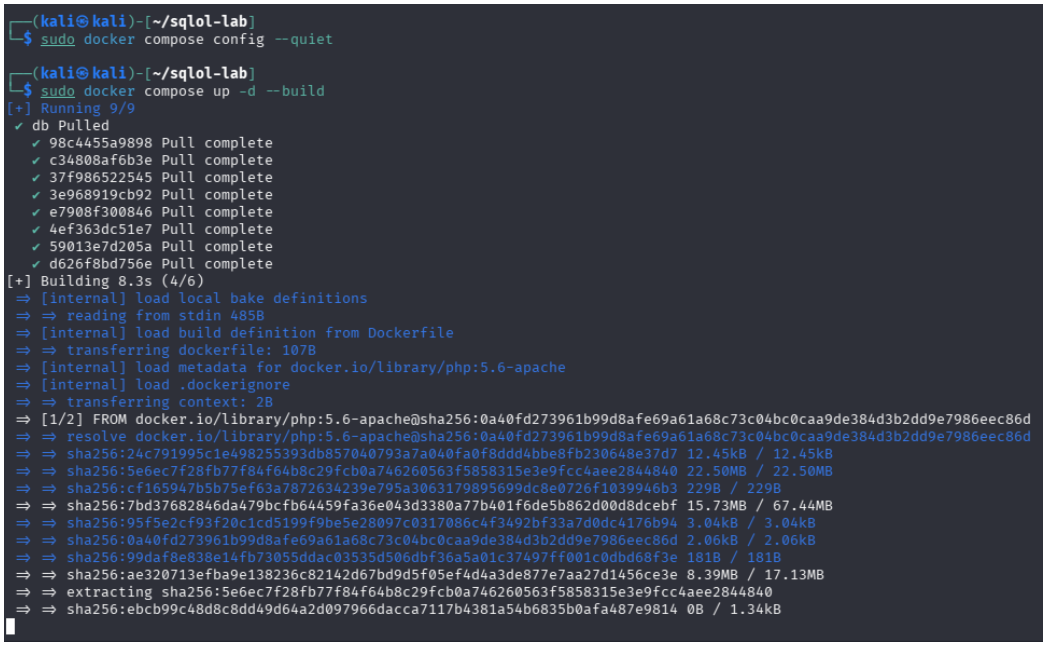

/*//Choose me for PostgreSQL
$dbtype = 'postgres';
$server = 'localhost';
$port = '5432';
$username = 'postgres';
$password = 'postgres';
$database = 'sqlol';
$persist = '';

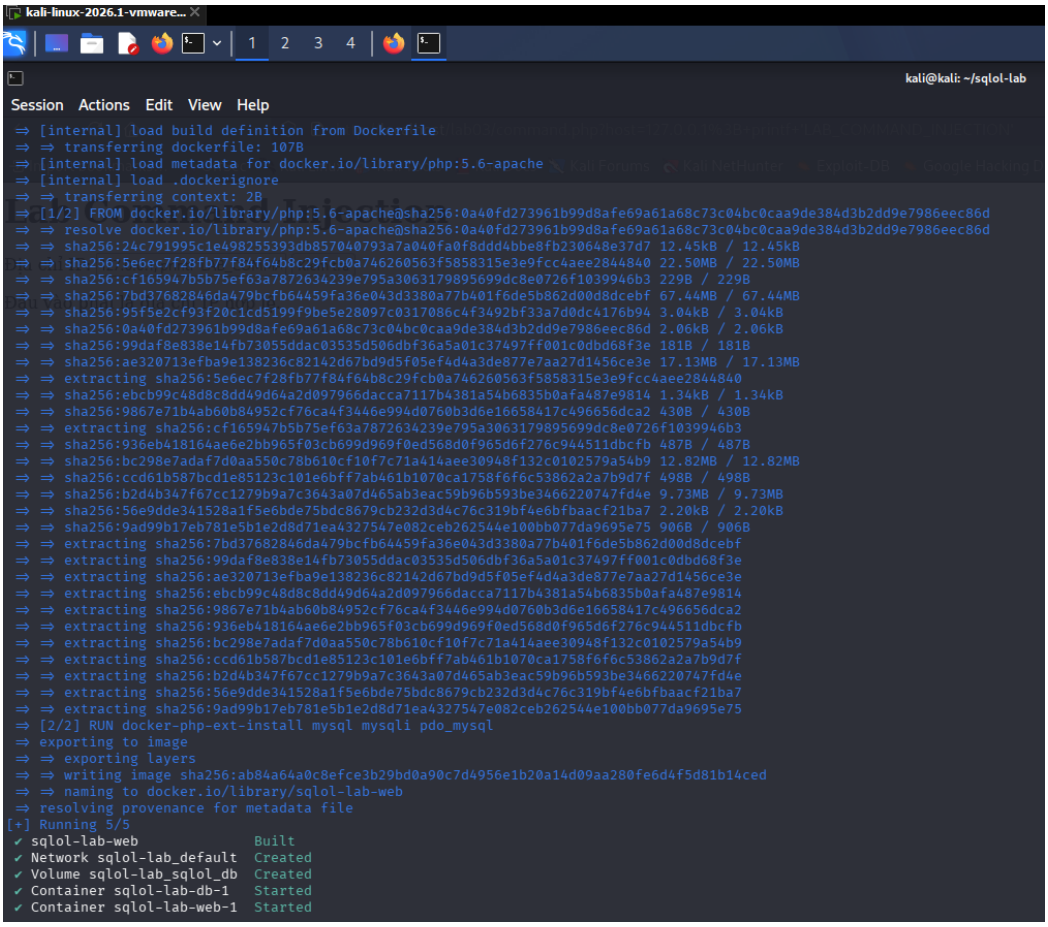
$hostspec = $username.':'.$password.'@'.$server.':'.$port;
*/

/*//Choose me for SQLite
$dbtype = 'sqlite';
$hostspec = urlencode('c:\path\to\sqlite.db');
$database = ''; //Keep this value set to null for SQLite
$persist = ''; //Don't persist, SQLite is bad at concurrent connections
*/

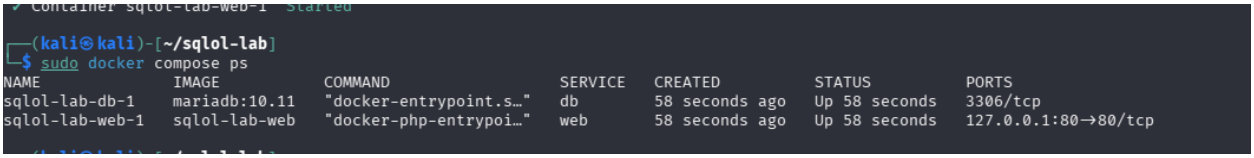
?>
```

Hình 14: Cấu hình SQLol kết nối MariaDB

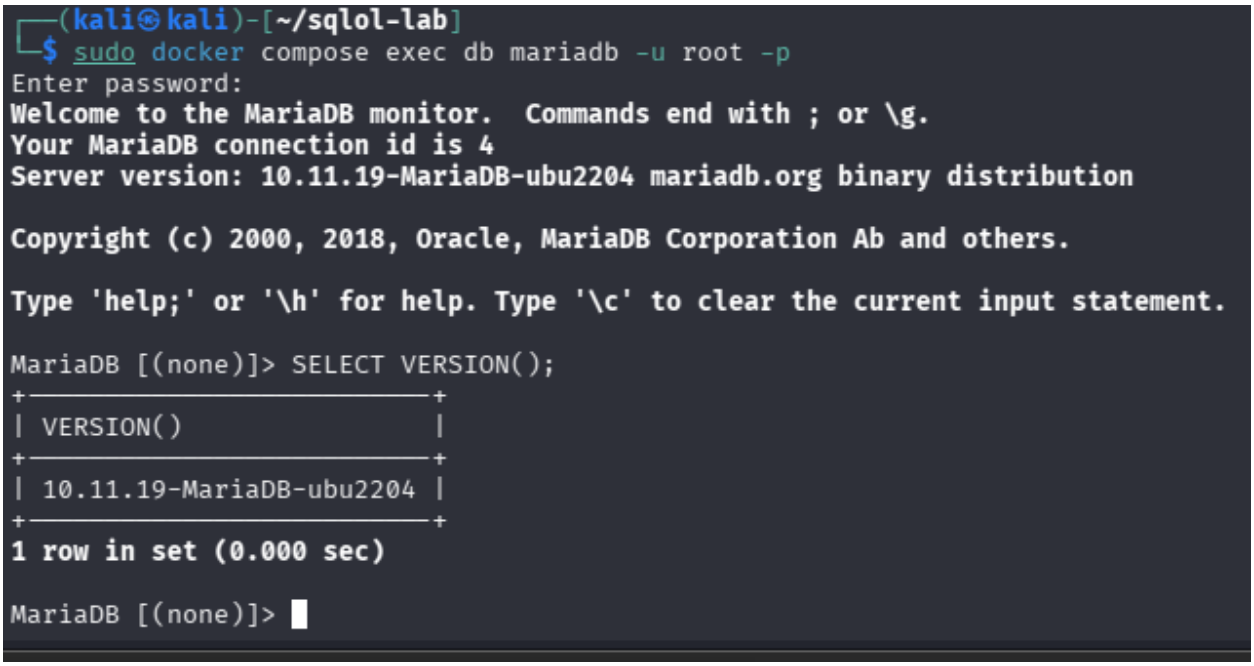




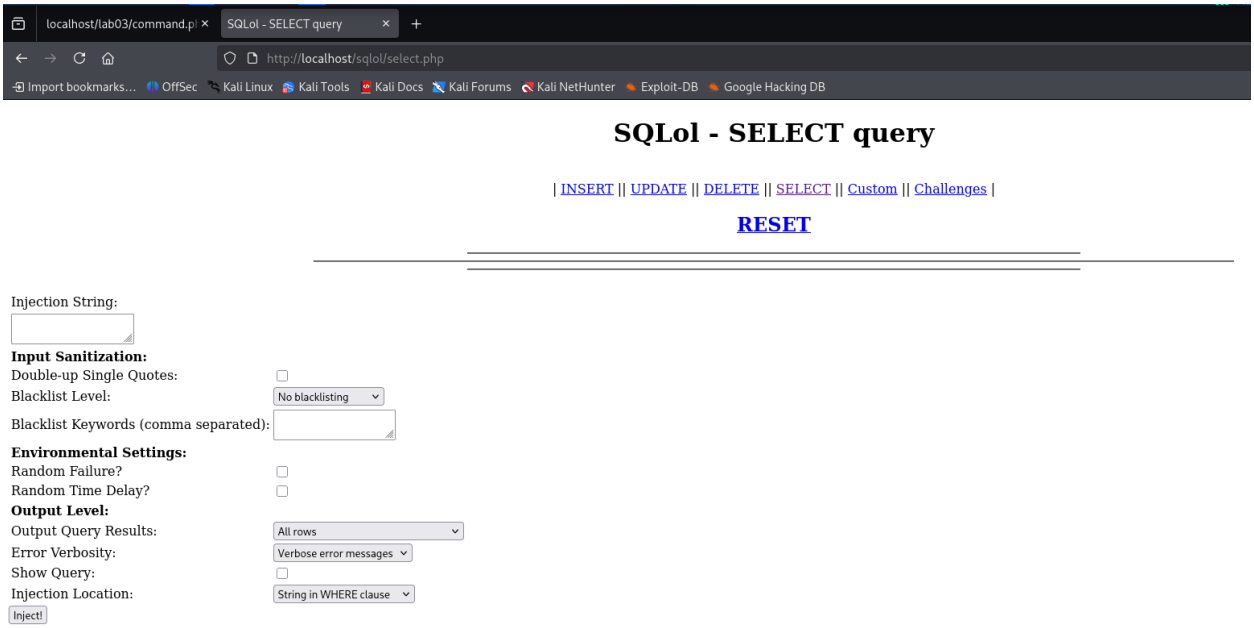
Hình 15: Build và khởi động docker



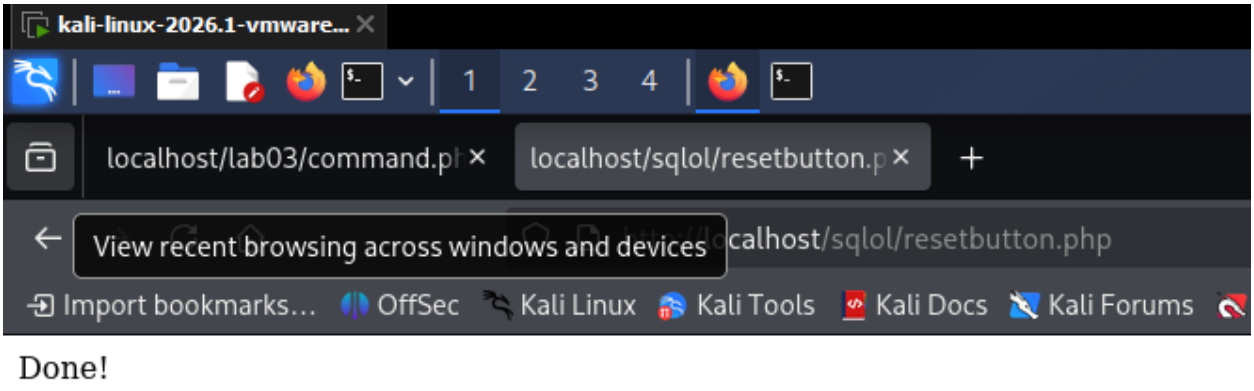
Hình 16: Kiểm tra cài đặt



Hình 17: Kiểm tra MariaDB

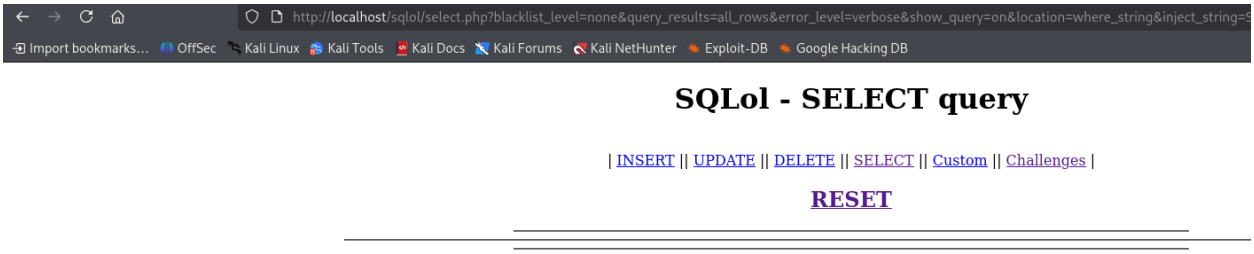


Hình 18: Truy cập trang web thành công

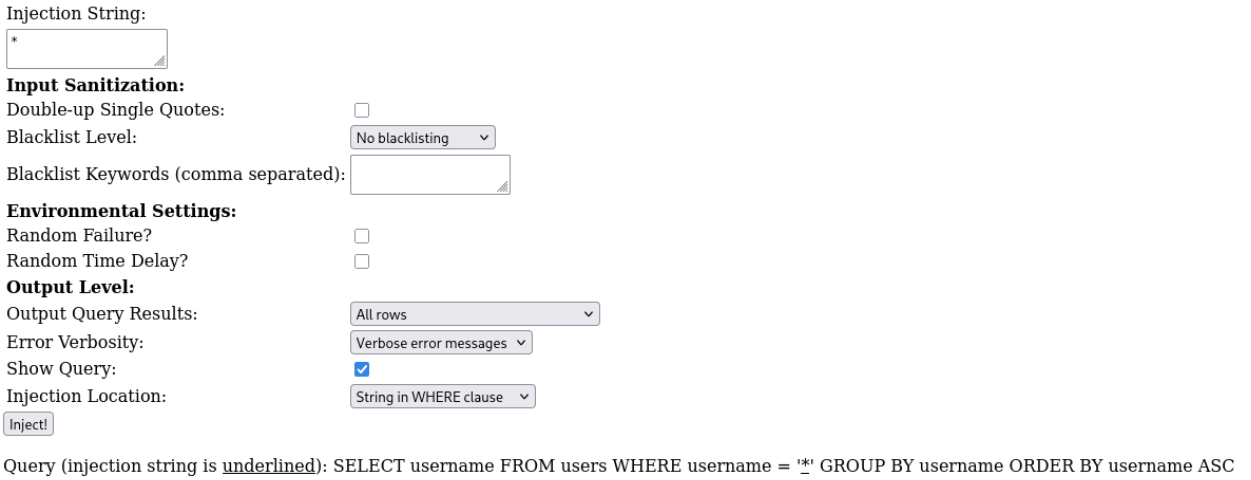


Hình 19: SQLol đã cài đặt thành công

Challenges 0



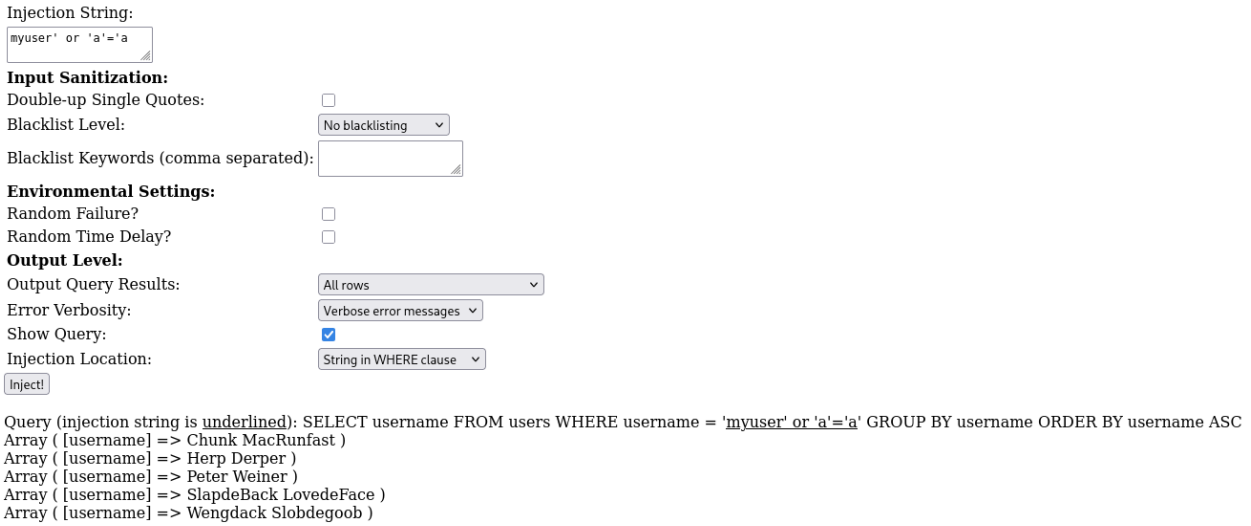
Hình 20: Nhập *student* và trả về kết quả



Hình 21: Nhập dấu hoa thị (*) và tên người dùng = '*' Không tồn tại

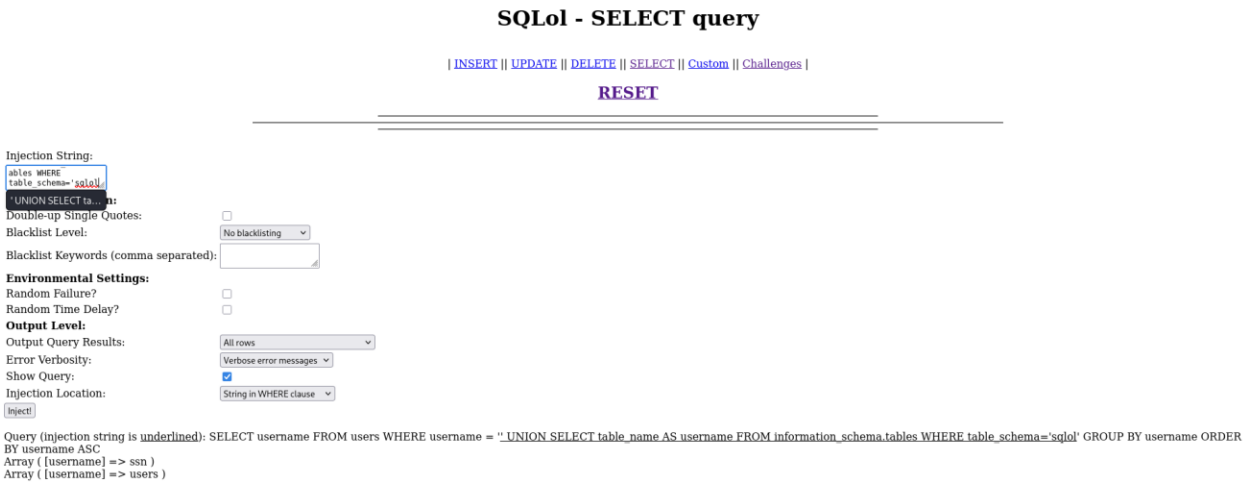


Hình 22: Lỗi cú pháp SQL khi nhập dấu nháy đơn

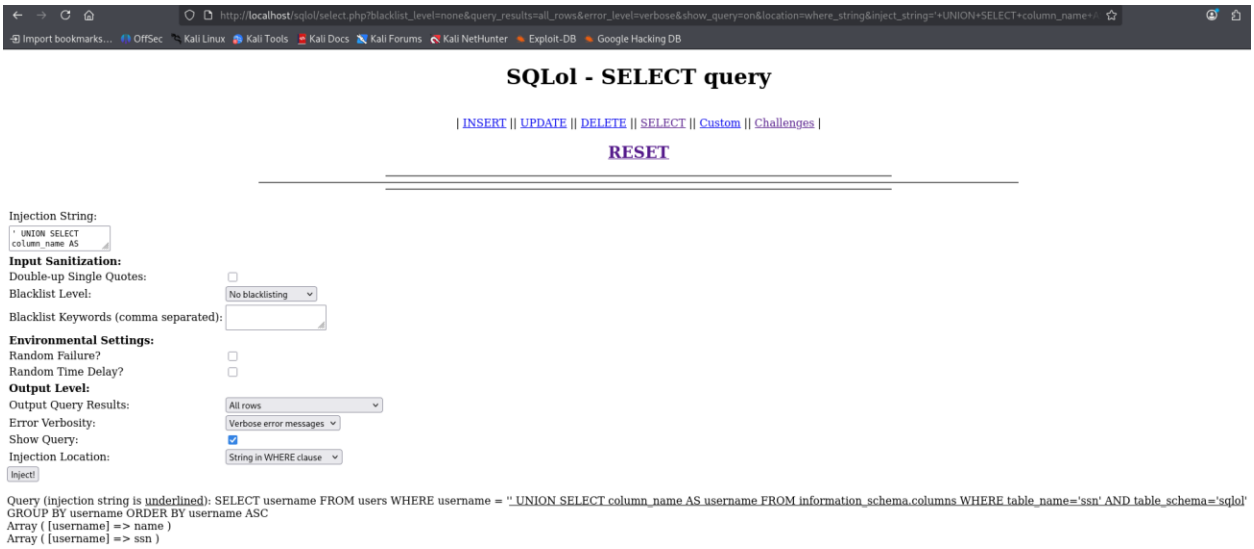


Hình 23: Khai thác thành công SQL Injection trong Challenge 0, trả về 5 username từ bảng users

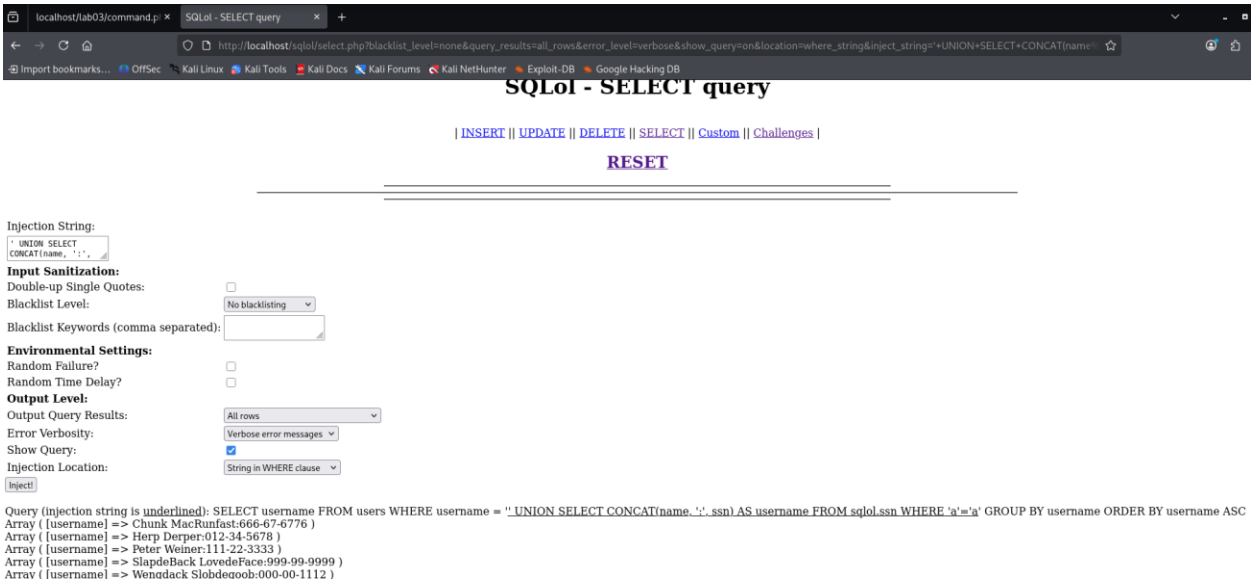
Challenges 1



Hình 24: Sử dụng UNION SELECT để xác định các bảng trong cơ sở dữ liệu *sqlol*. Kết quả cho thấy hai bảng *users* và *ssn*.

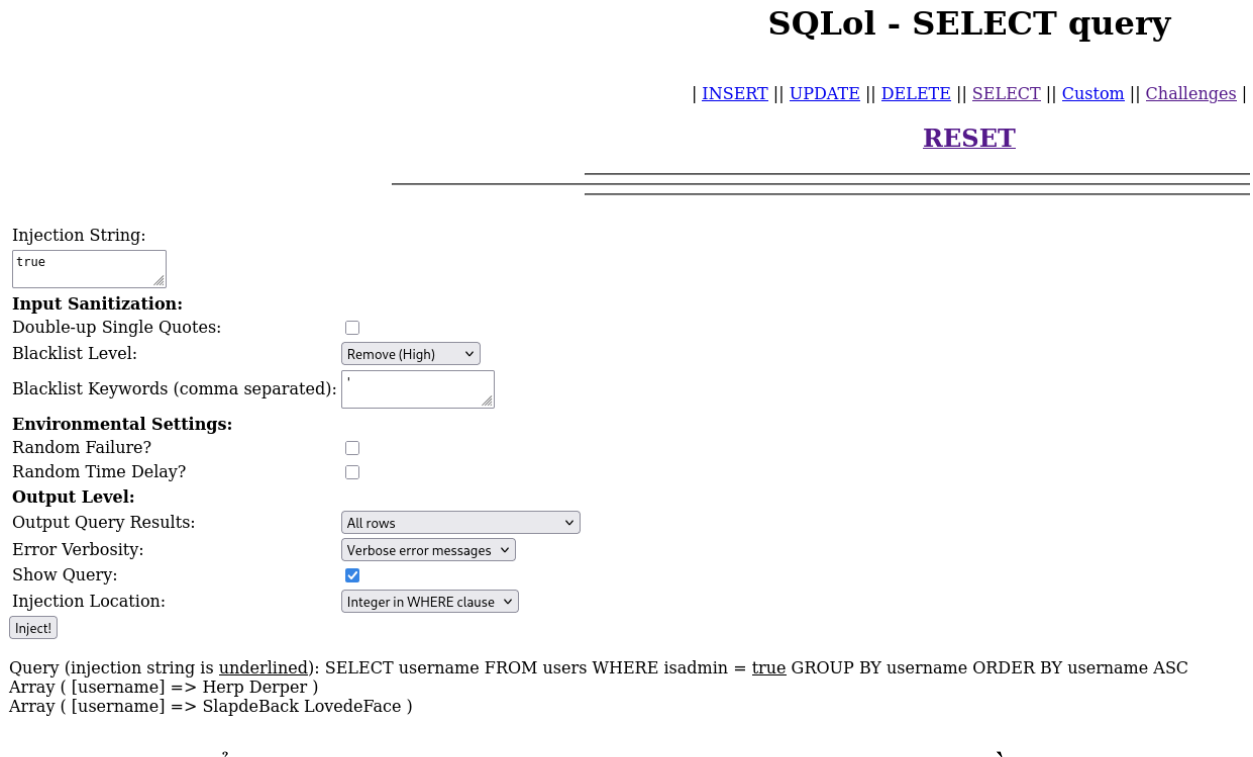


Hình 25: Truy vấn *information_schema.columns* để xác định các cột của bảng *ssn*, gồm *name* và *ssn*.

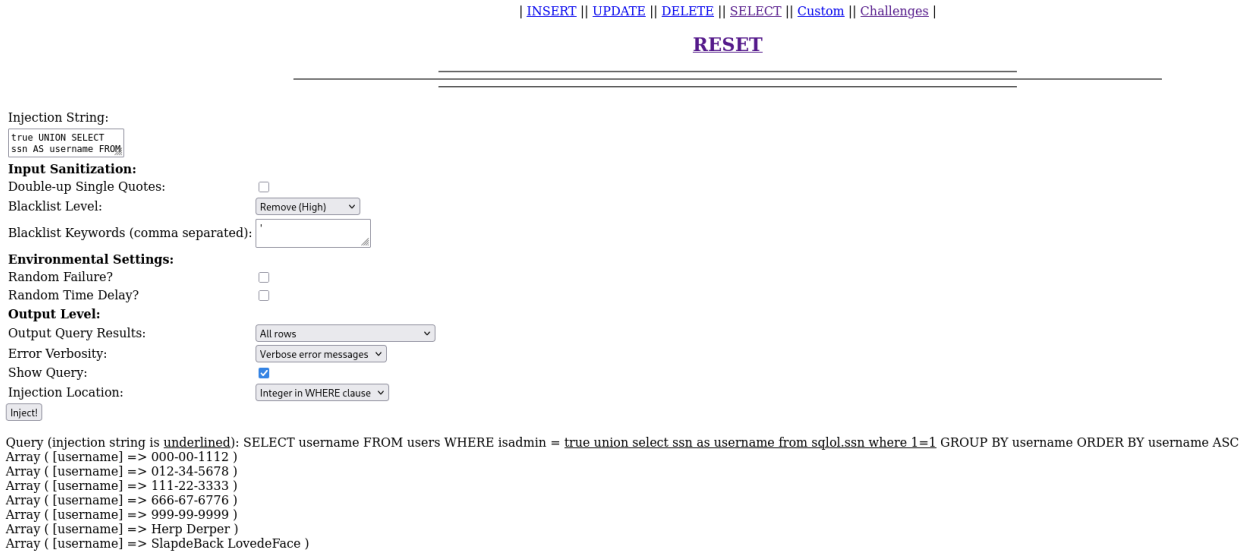


Hình 26: Khai thác SQL Injection bằng UNION SELECT thành công, truy xuất dữ liệu tên và SSN từ bảng *sqlol.ssn*.

Challenges 2



Hình 27: Kiểm tra trường Boolean *isadmin* với giá trị *true*, trả về các tài khoản quản trị viên.



Hình 28: Khai thác thành công SQL Injection trên trường Boolean bằng UNION SELECT, truy xuất dữ liệu SSN từ bảng *sqlol.ssn*.